

SIMATS ENGINEERING ASSESSMENT TOOL 01

**COURSE NAME: ETHICAL HACKING
COURSE CODE: ITA1408**

ANNEXURE A SECURITY TESTING SIMULATION TASK

Name:Gopika.S

Reg no:192421407

QUESTION 1 – WEB SERVER RECONNAISSANCE AND VULNERABILITY ANALYSIS

Objective: Gather information about the authorized vulnerable web server, identify exposed services, fingerprint technologies, enumerate web content, identify information disclosure and recommend hardening.

1.1 – Target Information

Item	Answer
Target Hostname	TO BE FILLED
Target IP Address	TO BE FILLED
Tester IP	TO BE FILLED
Testing Date/Time	TO BE FILLED

1.2 – Basic Network Reconnaissance

Commands used:

```
ping -c 4 <LAB_TARGET>
traceroute <LAB_TARGET>
ip a
ip route
# If Windows commands are required:
ipconfig
tracert <LAB_TARGET>
```

Observation: TO BE FILLED with the actual output and interpretation.

1.3 – Service and Version Identification

```
nmap -sV <LAB_TARGET>
nmap -sV -p 80,443 <LAB_TARGET>
```

Answer/Observation: Record open ports, service names and detected versions from the authorized target.

1.4 – Web Technology Identification

```
whatweb http://<LAB_TARGET>  
curl -I http://<LAB_TARGET>
```

Answer/Observation: Record web server, framework, cookies and security-related response headers.

1.5 – Web Vulnerability and Content Scanning

```
nikto -h http://<LAB_TARGET>  
gobuster dir -u http://<LAB_TARGET> -w <APPROVED_WORDLIST>
```

Answer/Observation: Record relevant findings such as exposed directories, backup files, configuration files or version disclosures.

1.6 – Findings

ID	Finding	Evidence/ Screenshot	Severity	Impact	Status
Q1-F01	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	Confirmed / False Positive
Q1-F02	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	Confirmed / False Positive
Q1-F03	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	Confirmed / False Positive

1.7 – Recommendations

- Disable unnecessary services and restrict exposed ports.
- Patch the web server and application components.
- Remove default pages, backup files and unnecessary directory listings.
- Restrict access to configuration and administrative resources.
- Hide unnecessary server-version information.
- Enforce HTTPS and secure file permissions.

Question 1 Conclusion: TO BE FILLED with a short summary of the main reconnaissance results and the most important hardening action.

QUESTION 2 – WEB APPLICATION VULNERABILITY ASSESSMENT

Objective: Identify application technologies and attack surface and assess common web-application vulnerabilities within the isolated authorized environment.

2.1 – Application Reconnaissance

Identify application pages and approved endpoints.

Identify forms, parameters, cookies, sessions and API requests.

Record the faculty-provided student and administrator test accounts.

```
whatweb http://<LAB_TARGET>
```

```
curl -I http://<LAB_TARGET>
```

2.2 – Request and Session Analysis

Area	What was checked	Evidence	Observation
Input fields	Forms and API parameters	TO BE FILLED	TO BE FILLED
Authentication	Login/logout and failed-login handling	TO BE FILLED	TO BE FILLED
Session	Cookies, expiration and rotation	TO BE FILLED	TO BE FILLED
Authorization	Role-based access	TO BE FILLED	TO BE FILLED
Error handling	Verbose errors and stack traces	TO BE FILLED	TO BE FILLED

Use OWASP ZAP or Burp Suite to capture representative requests and responses.

2.3 – Vulnerability Checks

Vulnerability	Safe validation approach	Evidence	Result
SQL Injection	Use a harmless lab-approved input and check whether input is safely handled.	TO BE FILLED	Confirmed / Not confirmed

Cross-Site Scripting	Use a harmless proof-of-concept permitted in the lab and check output encoding.	TO BE FILLED	Confirmed / Not confirmed
Insecure Authentication	Use only supplied test accounts and safe failed-login scenarios.	TO BE FILLED	Confirmed / Not confirmed
Session Weakness	Check cookie attributes, expiration, logout and rotation.	TO BE FILLED	Confirmed / Not confirmed
Directory Traversal	Use only a permitted non-destructive path-validation test.	TO BE FILLED	Confirmed / Not confirmed
Security Misconfiguration	Review headers, error messages and exposed resources.	TO BE FILLED	Confirmed / Not confirmed

2.4 – Findings and Remediation

ID	Vulnerability	Severity	Impact	Evidence	Remediation
Q2-F01	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED
Q2-F02	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED
Q2-F03	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED
Q2-F04	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED

Question 2 Conclusion: TO BE FILLED with the confirmed vulnerabilities, their impact and the most important secure- coding recommendation.

QUESTION 3 – SECURITY HEADER AND HTTPS CONFIGURATION ASSESSMENT

Objective: Assess HTTPS/TLS and security-header configuration of the authorized application.

3.1 – HTTP Response Headers

```
curl -I http://<LAB_TARGET>
curl -I https://<LAB_TARGET>
```

Record the actual response headers and explain whether they provide appropriate protection.

3.2 – TLS Configuration

```
nmap --script ssl-enum-ciphers -p 443 <LAB_TARGET>
```

Record supported TLS versions, cipher suites and certificate-related observations.

3.3 – HTTPS Redirect

Test the HTTP endpoint and verify whether it redirects to HTTPS. Record the status code and Location header.

3.4 – Security Header Assessment

Control	Expected Secure State	Actual Observation	Risk	Recommendation
Content-Security-Policy	Restricts script/resource sources	TO BE FILLED	TO BE FILLED	TO BE FILLED
Strict-Transport-Security	Forces HTTPS where appropriate	TO BE FILLED	TO BE FILLED	TO BE FILLED
X-Frame-Options / frame-ancestors	Reduces clickjacking risk	TO BE FILLED	TO BE FILLED	TO BE FILLED
X-Content-Type-Options	nosniff present	TO BE FILLED	TO BE FILLED	TO BE FILLED
Secure cookies	Secure/HttpOnly/ SameSite as appropriate	TO BE FILLED	TO BE FILLED	TO BE FILLED

3.5 – TLS and Certificate Assessment

Item	Actual Result	Severity	Recommendation
TLS versions	TO BE FILLED	TO BE FILLED	TO BE FILLED
Cipher suites	TO BE FILLED	TO BE FILLED	TO BE FILLED
Certificate validity	TO BE FILLED	TO BE FILLED	TO BE FILLED
HTTP → HTTPS redirect	TO BE FILLED	TO BE FILLED	TO BE FILLED

Question 3 Conclusion: TO BE FILLED with the main HTTPS/header weakness and its security impact.

QUESTION 4 – BROKEN ACCESS-CONTROL ASSESSMENT

Objective: Determine whether a normal student test account can access another student's test record or administrator-only test resources in the authorized laboratory.

4.1 – Test Accounts

Account	Role	Faculty-provided Identifier	Permitted Test
A	Student	TO BE FILLED	Own student record
B	Student	TO BE FILLED	Other approved test record
C	Administrator	TO BE FILLED	Admin-only test resource

4.2 – Testing Procedure

1. Log in using the authorized student test account.
2. Capture the normal request for the student's own resource using OWASP ZAP or Burp Suite.
3. Identify the object identifier used by the application.
4. Using only a faculty-provided test identifier, repeat the request and observe whether authorization is enforced.
5. Where explicitly permitted, request an administrator-only test resource while authenticated as the student account.
6. Compare status codes, response content and access behaviour.
7. Do not modify or delete records and do not access real user information.

4.3 – Authentication vs Authorization

Concept	Meaning	Example
Authentication	Confirms the identity of the user.	Student logs in with supplied test credentials.
Authorization	Determines what the authenticated user can access.	Student cannot access admin-only resources.

4.4 – Access- Control Results

ID	Test	Observed Response	Finding	Severity	Impact	Recommendation
Q4-F01	Student → own resource	TO BE FILLED	Expected/Issue	TO BE FILLED	TO BE FILLED	TO BE FILLED
Q4-F02	Student → other approved test resource	TO BE FILLED	Expected/Issue	TO BE FILLED	TO BE FILLED	TO BE FILLED
Q4-F03	Student → admin-only resource	TO BE FILLED	Expected/Issue	TO BE FILLED	TO BE FILLED	TO BE FILLED

Question 4 Conclusion: TO BE FILLED with whether server-side authorization was correctly enforced.

QUESTION 5 – AUTOMATED SCANNING AND MANUAL VALIDATION

Objective: Use approved automated tools, compare their findings and manually validate at least three selected findings within the authorized laboratory.

5.1 – Nikto Scan

```
nikto -h http://<LAB_TARGET>
```

Record the actual scanner output and identify relevant findings.

5.2 – Wapiti / OWASP ZAP Scan

```
wapiti -u http://<LAB_TARGET>
```

For OWASP ZAP, record the target, scope, scan type, alert count and important alert details from the generated report.

5.3 – Automated Findings Comparison

Finding	Tool	Category	Automated Result	Manual Validation	Final Status
F-01	TO BE FILLED	Misconfiguration	TO BE FILLED	TO BE FILLED	Confirmed / False Positive / Investigate
F-02	TO BE FILLED	Information Disclosure	TO BE FILLED	TO BE FILLED	Confirmed / False Positive / Investigate
F-03	TO BE FILLED	Authentication / Session	TO BE FILLED	TO BE FILLED	Confirmed / False Positive / Investigate
F-04	TO BE FILLED	Injection	TO BE FILLED	TO BE FILLED	Confirmed / False Positive / Investigate

5.4 – Manual Validation of Three Findings

ID	Selected Finding	Validation Method	Evidence	Result	Severity	Impact	Remediation
----	------------------	-------------------	----------	--------	----------	--------	-------------

MV-01	TO BE FILLED	Safe manual check	TO BE FILLED	Confirmed / False Positive	TO BE FILLED	TO BE FILLED	TO BE FILLED
MV-02	TO BE FILLED	Safe manual check	TO BE FILLED	Confirmed / False Positive	TO BE FILLED	TO BE FILLED	TO BE FILLED
MV-03	TO BE FILLED	Safe manual check	TO BE FILLED	Confirmed / False Positive	TO BE FILLED	TO BE FILLED	TO BE FILLED

5.5 –Final Risk Summary

Finding	Severity	Likelihood	Impact	Priority	Recommended Action
TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	High/Med/Low	TO BE FILLED
TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	High/Med/Low	TO BE FILLED
TO BE FILLED	TO BE FILLED	TO BE FILLED	TO BE FILLED	High/Med/Low	TO BE FILLED

Question 5 Conclusion: TO BE FILLED with the comparison between automated and manual results and the final remediation priorities.

FINAL CONSOLIDATED CONCLUSION

The assessment covers the five required security-testing activities separately: web-server reconnaissance, web-application vulnerability assessment, HTTPS/security-header review, access-control assessment, and automated scanning with manual validation. The final submitted version should contain the student's real laboratory outputs, screenshots and confirmed findings. Automated scanner alerts should be treated as leads until safely validated. All testing must remain within the authorized isolated laboratory scope.

Evidence Checklist

- [] Q1: Reconnaissance, Nmap, WhatWeb, Nikto and Gobuster evidence attached.
- [] Q2: ZAP/Burp requests, responses and vulnerability validation evidence attached.
- [] Q3: HTTP headers, HTTPS redirect and TLS assessment evidence attached.
- [] Q4: Authorized student/admin access-control comparison evidence attached.
- [] Q5: Automated scan reports and manual validation evidence for at least three findings attached.

References

8. OWASP Foundation – OWASP Top 10.
9. OWASP Foundation – Web Security Testing Guide.
10. OWASP Foundation – ZAP Documentation.
11. Nmap Project – Nmap Reference Guide.
12. NIST – Cybersecurity Framework (CSF) 2.0.
13. IETF – RFC 8446, Transport Layer Security (TLS) 1.3.